Role Permissions Workshop

Macavation Portal · Phase 2, Epic 2 · Prepared 28 July 2026

The purpose of this session is to produce one signed decision: **which of the eight roles may perform each of twenty-five sensitive actions.** Development cannot proceed on this part of Phase 2 without it, because the answer is a business judgement, not a technical one.

Please read sections 1 to 3 before the meeting. Section 4 is the decision grid we will fill in together.

1. What we are deciding, in plain terms

The portal controls access in two separate places, and they are currently out of step with each other.

Layer	What it does	Today
The buttons `actions`	Decides which buttons a person can see on screen.	Six of the eight roles can see only **2 of the 25** controlled buttons.
The engine `role_permissions`	Decides what the system will actually carry out when asked.	Every role, including Shareholder, is permitted **186 or more** operations.

> **This gap is the reason for the meeting.** Hiding a button does not stop the underlying operation. A person whose screen shows no "Adjust stock" button is still permitted to adjust stock by the engine behind it. Access that exists only on screen is not access control.

So each decision we make has to be applied in both places. That is straightforward once the decision exists — but it has to exist first, and only Macavation can make it.

2. What is true today

Taken from the live UAT system on 28 July 2026.

Role	Buttons visible of 25	Operations permitted by the engine	People
super_user	25	340	7
admin	25	340	1
Factory Manager	2	186	1
Production Manager	2	188	1
Palladium Manager	2	186	1
Quality Assurance	2	186	1
Sales Exec	2	186	2

Shareholder	2	186	2

Two things stand out and are worth confirming before we start.

- **Seven people hold super_user.** That is the most powerful role in the system and currently the most widely held. Worth asking whether all seven still need it.
- **Shareholder carries the same engine permissions as Factory Manager.** A shareholder account is permitted to approve job cards, adjust stock on hand, complete batches, create dispatch orders and import historical data. These are almost certainly not intended.

Spot check — who the engine currently permits

Operation	Roles the engine permits today
Adjust stock on hand	All eight roles
Approve a kernel job card	All eight roles
Complete a kernel batch	All eight roles
Create a dispatch order	All eight roles
Import historical batch data	All eight roles
Add or change a user	admin, super_user only — correctly restricted

3. How to decide — three questions per action

1. **Who does this as part of their job?** Not who could be trusted with it — who actually performs it in the normal running of the plant.
2. **What is the damage if it is done wrong?** A mistyped stock adjustment quietly corrupts every stock figure and every report that follows from it. A wrongly approved job card affects one batch. These deserve different answers.
3. **Who covers when that person is away?** The most common reason a permission gets handed out permanently is a one-off absence. Decide the cover now instead.

> **When a role is genuinely borderline, leave it off.** Granting access later takes minutes and no one is harmed while they wait. Discovering months afterwards that the wrong person has been adjusting stock cannot be undone, because the corrupted history is already in the reports.

4. Decision grid

Tick every role that **should** be allowed to perform each action. A blank box means not allowed.

admin and **super_user** are not listed: they are permitted everything by design, and that is what we are asking you to confirm in question 1 on the last page.

Action	Factory Manager	Production Manager	Palladium Manager	Quality Assurance	Sales Exec	Share-holder
Stock						
Adjust stock on hand `stock.adjust_soh`	☐	☐	☐	☐	☐	☐
Dispatch stock `stock.dispatch`	☐	☐	☐	☐	☐	☐
Import or add a stock batch `stock.import_batch`	☐	☐	☐	☐	☐	☐
Manage shell waste stock `stock.shell.manage`	☐	☐	☐	☐	☐	☐
Manage stock alert rules `stock.alert_rules.manage`	☐	☐	☐	☐	☐	☐
Kernel Production						
Create a kernel batch `kernel.batch.create`	☐	☐	☐	☐	☐	☐
Approve a job card `kernel.job_card.approve`	☐	☐	☐	☐	☐	☐
Edit production stages `kernel.production_stages.edit`	☐	☐	☐	☐	☐	☐
Release a batch to stock `kernel.release_to_stock`	☐	☐	☐	☐	☐	☐
Kernel Dispatch						
Create a dispatch order `kernel.dispatch.create`	☐	☐	☐	☐	☐	☐
Edit a dispatch order `kernel.dispatch.edit`	☐	☐	☐	☐	☐	☐
Oil Production						
Create an oil batch `oil.batch.create`	☐	☐	☐	☐	☐	☐
Edit the oil production sheet `oil.production.edit`	☐	☐	☐	☐	☐	☐
Release an oil batch `oil.production.release`	☐	☐	☐	☐	☐	☐
Manage consolidated batches `oil.consolidated.manage`	☐	☐	☐	☐	☐	☐
Quality Assurance						
Create a quality test `qa.test.create`	☐	☐	☐	☐	☐	☐
Approve a quality test `qa.test.approve`	☐	☐	☐	☐	☐	☐
Grower Intake						
Create an intake batch `grower.intake.create`	☐	☐	☐	☐	☐	☐
Manage the procurement calendar `grower.procurement.manage`	☐	☐	☐	☐	☐	☐

Dashboard & Reporting						
Resolve alerts `alerts.resolve`	☐	☐	☐	☐	☐	☐
Manage dashboard targets `dashboard.targets.manage`	☐	☐	☐	☐	☐	☐
Manage scheduled reports `reports.schedule.manage`	☐	☐	☐	☐	☐	☐
Manage report subscriptions `reports.subscribe`	☐	☐	☐	☐	☐	☐
Messaging & Administration						
Send a broadcast message `messaging.broadcast`	☐	☐	☐	☐	☐	☐
Manage users and roles `admin.users.manage`	☐	☐	☐	☐	☐	☐

5. Questions to settle

1. Seven people hold super_user, which permits everything. Should all seven keep it, and who is accountable for approving the list?

2. What should Shareholder actually be able to do? Our assumption is view and report only, with no ability to change operational data. Please confirm or correct.

3. What is Palladium Manager? It currently mirrors Factory Manager exactly. If the two roles do different jobs, we need to know where they differ.

4. Should stock adjustment require a second person's approval? It is the single most damaging action in the system, because a wrong figure silently flows into every report afterwards. Today it needs one person and no approval.

5. Who covers each role during leave? Name the cover per role now, so absence does not become a reason to widen access permanently.

6. Suggested agenda — 90 minutes

10 min	Walk through what is true today (section 2). Agree that the gap needs closing.
10 min	Settle questions 1 to 3 — the roles themselves, before the detail.
45 min	Work the decision grid module by module. Roughly two minutes per action.
15 min	Questions 4 and 5 — approval for stock adjustment, and leave cover.
10 min	Confirm the grid, sign, agree the date for the walkthrough.

7. What happens after the meeting

1. The signed grid is turned into a database change that sets both layers together — the buttons and the engine. Neither is done on its own.
2. It is applied to UAT first, never straight to production.
3. Each role is then tested by signing in as it and confirming that permitted actions work and the rest are genuinely refused — not merely hidden.
4. Only then is it applied to production, and the user guide updated.

> **Expect some access to be removed on the day it goes live.** Six roles currently hold far more than they will keep. Tell the affected people beforehand, and make sure everyone knows who to ask when something they used to be able to do stops working.

8. Sign-off

The grid in section 4 is agreed as the intended access for the Macavation portal.

Name	Role	Signature	Date

Figures in sections 2 and 3 were read from the live UAT database (`nmdmddugxclpqrwylyfa`) on 28 July 2026 and reflect the system as it stood that day. Action keys are listed in monospace so each decision can be traced to the exact control it governs.